Part 3 Brief · Hardening

mcp-ops-server · 18 Oct 2026 · PR #4 · Status: Codex review fixed (2x P1, 1x P2), 119 tests, ready to merge

WHAT WAS BUILT

- **Bearer-token auth.** No token or a wrong one gets HTTP 401. Tokens are stored only as SHA-256 hashes, and the server refuses to start without a tokens file (fails closed).
- **Scopes and patient binding, checked in server code.** Each tool needs its scope (`read:schedule`, `write:schedule`, `read:referrals`). A token bound to one patient can only book, cancel or read referrals for that patient.
- **Limits:** a per-client rate limit on every tool call, a 64 KiB request cap (SDK default: 4 MiB), one time limit per call covering all waits, and 100 sessions with a 10-minute idle timeout.
- **Simulated clinic clock** (default Mon 2 Nov 2026, 08:00): past slots are hidden and can't be booked. **Schema snapshot test:** any change to what agents see fails CI until approved.

HOW IT WORKS

Piece	Role
SDK middleware	Verifies the bearer token on every HTTP request and puts it in a context variable the tools can read.
Guard	Every tool call is rate-limited before its arguments are even validated. Then each tool checks: authenticated? has the scope? right patient? Refusals never touch the database.
Store	One deadline per call, set before any waiting. Lock waits and SQLite busy waits use the time left; a slow statement is interrupted; a late write rolls back instead of committing.

WHY IT WAS DONE THIS WAY

- **Security lives in code, not prompts.** Tools check the token themselves, so even a call that skips HTTP (as the unit tests do) is refused without one.
- **Interrupt inside SQLite, don't abandon a thread.** A thread can't be killed; a thread timeout would report "failed" while the booking still committed. Interrupting SQLite rolls it back.
- **Simulated time.** A real clock would make every synthetic slot "past" after November 2026 and break the evals. `MCP_OPS_NOW=system` switches to the real clock.

WHAT WENT WRONG OR SURPRISED ME (LOGGED IN FAILURES.MD)

- **The schema test caught a real bug on its first CI run:** Python 3.12 keeps docstring indents, 3.13 strips them, so agents saw different tool descriptions. Now normalized; tests pass on both.
- **The obvious timeout was wrong** (see above). Caught at design time; a test proves a timed-out write never lands.
- **Codex review: 2x P1, 1x P2, all reproduced, then fixed.** The time limit ignored lock waits (a call took 336 ms against a 200 ms limit). Tokens sharing a client name could delete each other's sessions. Invalid calls and health skipped the rate limit. Each fix has a test that fails with the bug put back.

VERIFY IT YOURSELF

```
python -m mcp_ops_server.auth issue --file tokens.json --client dev \
    --scope read:schedule --scope write:schedule --scope read:referrals   # prints token
MCP_OPS_TOKENS_FILE=tokens.json python -m mcp_ops_server   # 401 without the token
ruff check . && python -m pytest -q                        # 119 passed
```

INTERVIEW TALKING POINT

"Authorization is enforced inside every tool, not in the prompt and not only at the HTTP edge. A token bound to one patient can't book for another, even if the model is tricked into asking. And every protection has a test that fails when I delete it."

NEXT: PART 4, EVALS

A golden set of about 30 tasks, a step-by-step (trajectory) grader, a replay agent that needs no LLM, and a report. **Your action:** merge PR #4, then reply "go".